

腾讯云数据安全和隐私保护

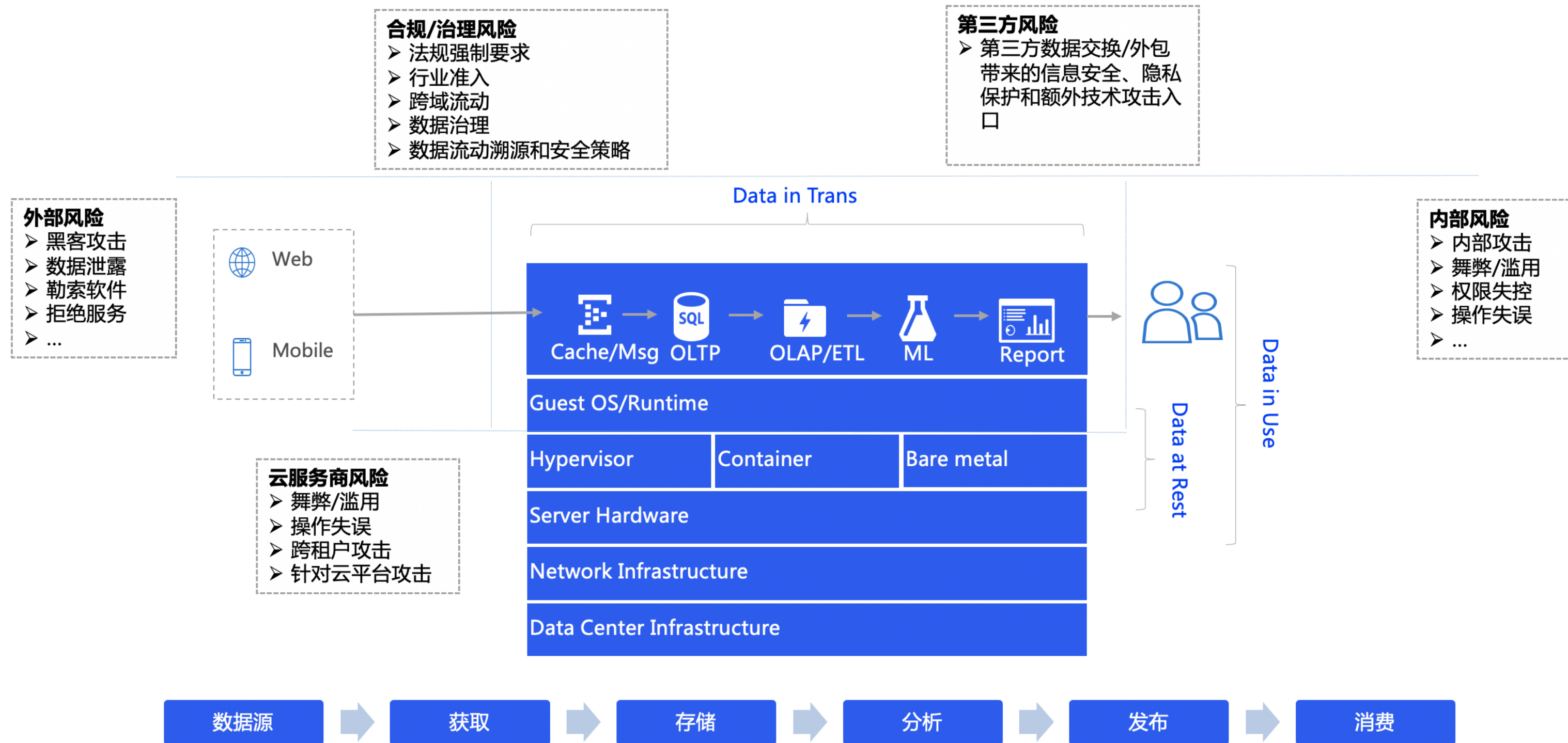
演讲嘉宾·姬生利

2021首届-西部云安全峰会
Western China Cloud Security Summit 2021



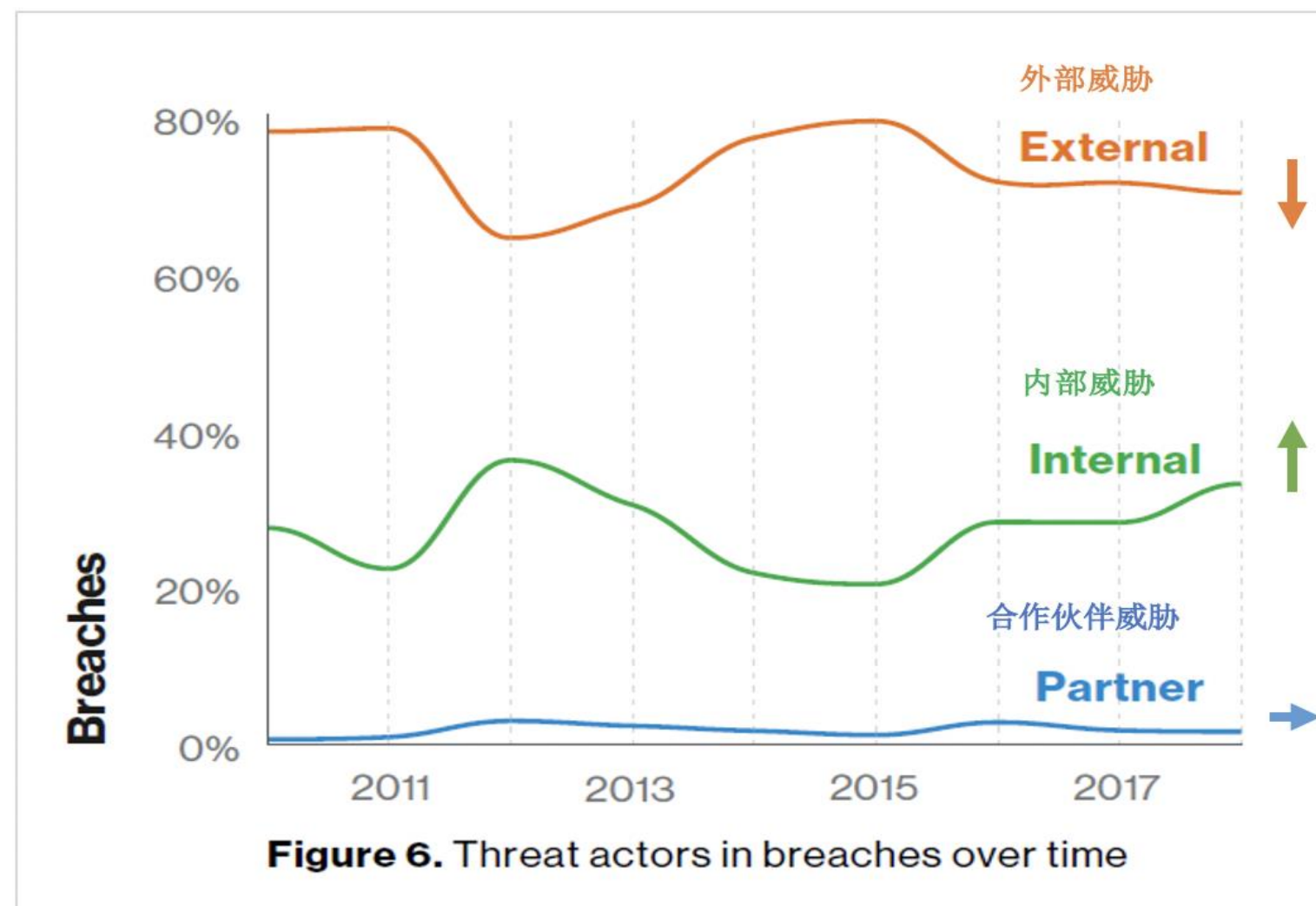
目录

- 1 数据上云面临的数据安全问题
- 2 腾讯云数据安全架构和实践
- 3 腾讯云数据安全和隐私保护解决方案介绍

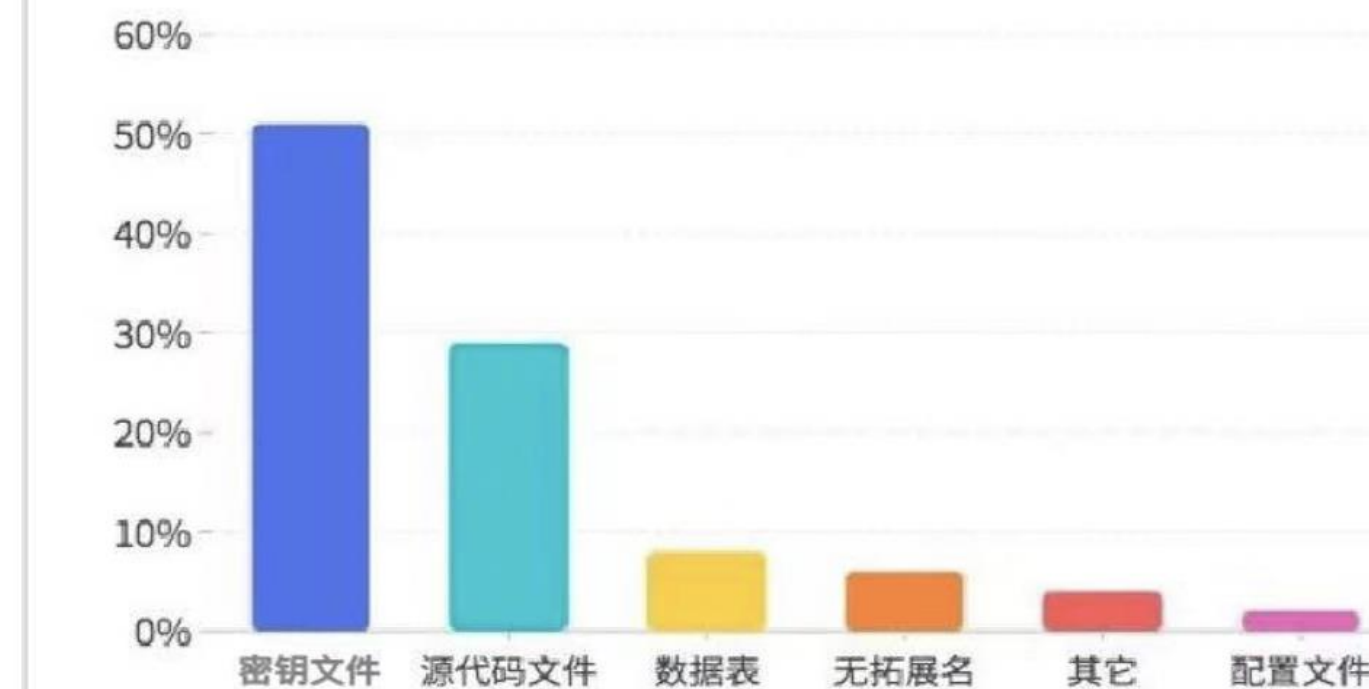


常见问题

- 内部原因导致问题上升
- 密钥管理不当
- 敏感账号密码明文配置, *Hard Code*问题严重



密钥所在的文件类型百分比



不安全的配置、源代码泄露及硬编码带来的数据泄露事件

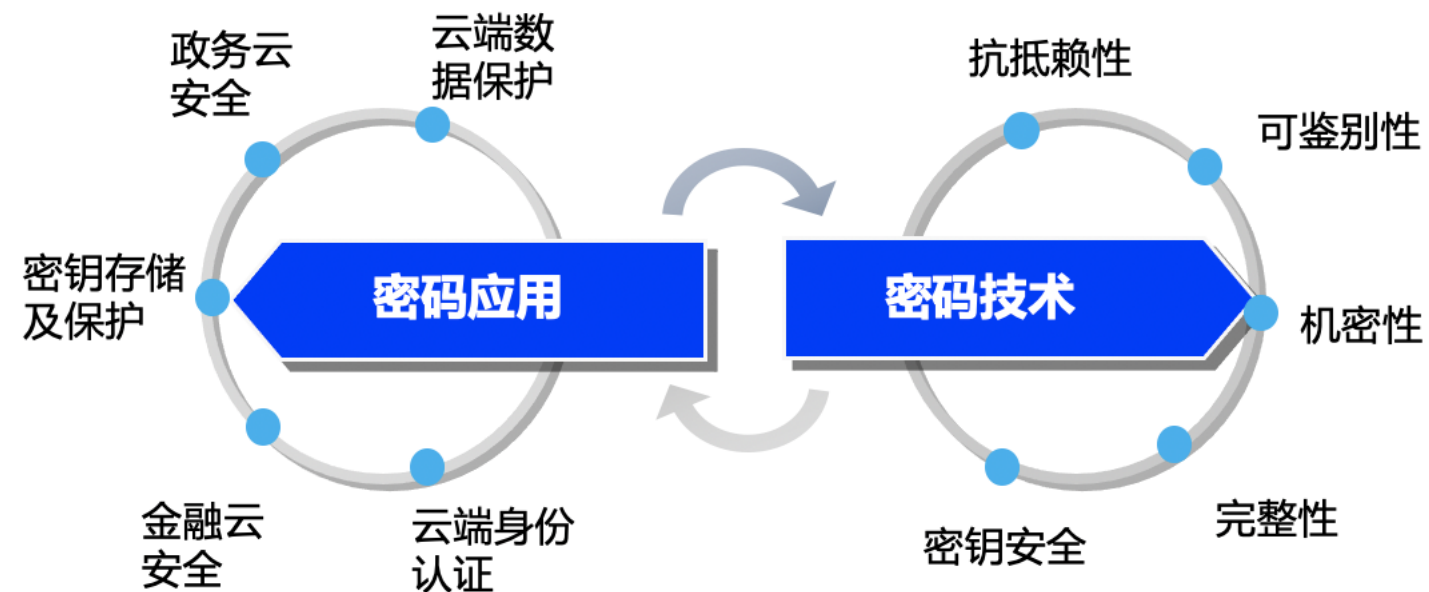
- Facebook被曝涉及4.19亿用户手机号码数据泄露。事件原因为服务器没有设置保护措施!
- 多起公司源码泄露事件, 内含硬编码的用户名密码等敏感凭据信息!
- 超100000万个 GitHub 仓库泄露了 API 及加密密钥!

业务安全

- 提供数据传输、数据存储等过程中的机密性和完整性保护；
- 完善的密钥生命周期管理，保证密钥产生和运算过程的安全；
- 保护金融支付、电子政务、身份认证等业务过程的安全；

合规要求

- 满足外部合规需求，如密码法应用要求、等保安全合规建设等，系统安全标准PCI DSS、SOC、第三方支付认证等；
- 满足内部审计管理策略。

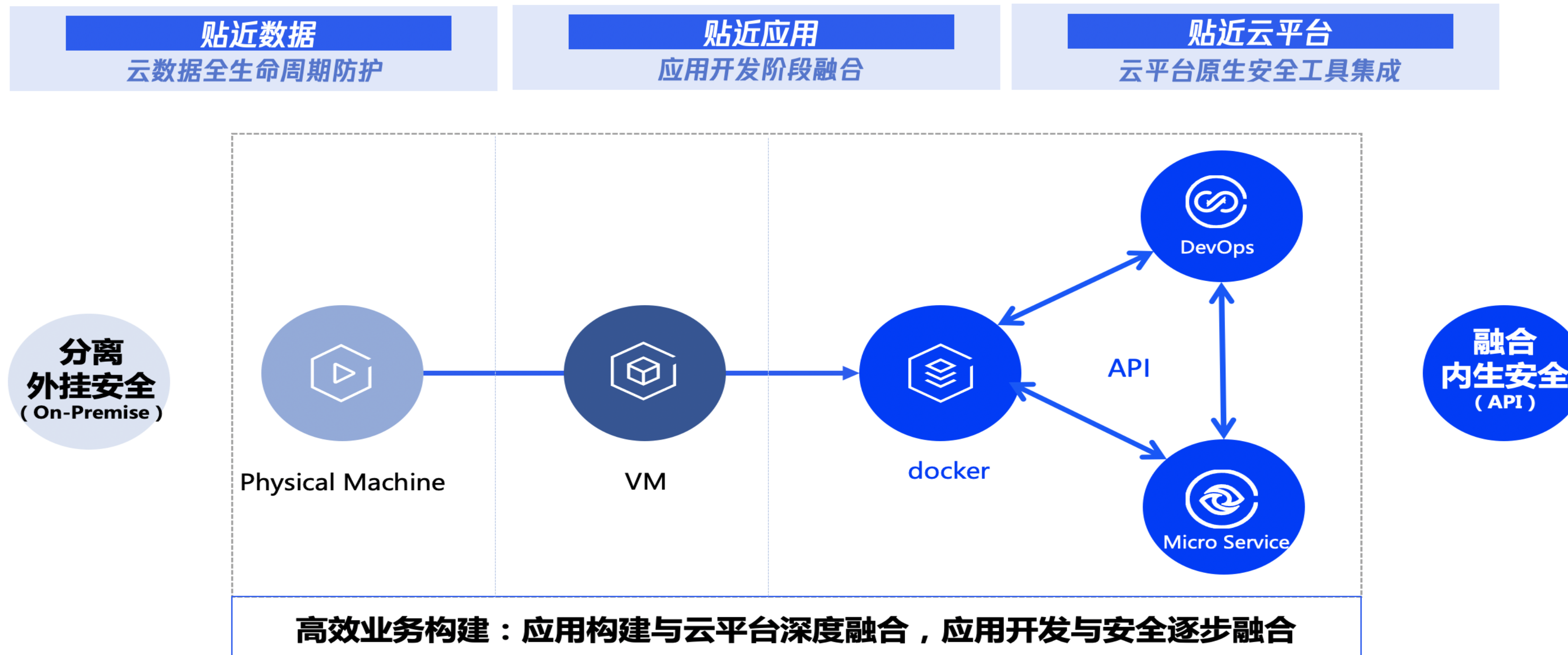


国内合规标准

- 《密码法》
- 《个人信息保护法》
- 《网络安全等级保护条例（征求意见稿）》
- 《关键信息基础设施安全保护条例（征求意见稿）》
- 《网络安全法》
- 《政务信息系统政府采购管理暂行办法》
- 《商用密码管理条例》
- 《金融领域密码应用指导意见》
- 《重要领域密码应用指导意见》
- 《密码应用与创新发展的工作规划》
- 《公安机关商用密码应用安全性评估管理办法（试行）》
- 《公安机关商用密码应用指南（试行）》
- ...

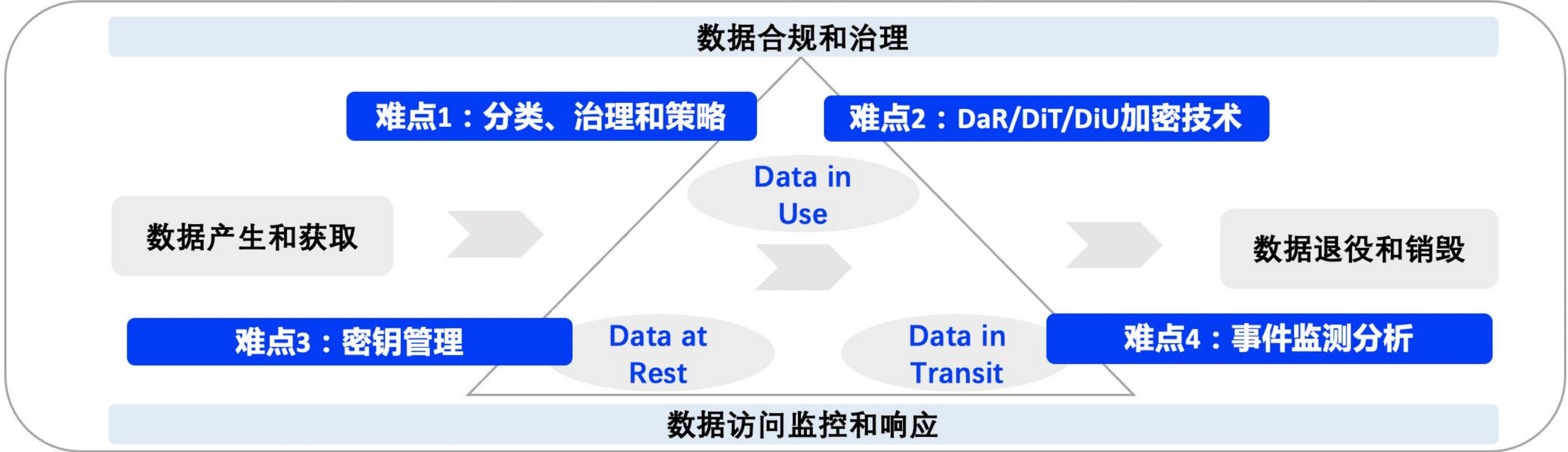
国际合规标准

- PCI DSS
- SOC
- CSA
- HIPAA
- EU GDPR
- HK CAP 486...
- GLBA
- SOX
- ...



2 腾讯云数据安全架构和实践

在数据整个生命周期，不同的状态面临不同的保护难点，需要针对数据的状态提供简单、有效的数据安全保护方案



Data-at-Rest	Data-in-Use	Data-in-Transit
➤ 存储加密(卷/对象/文件) ➤ 访问控制 ➤ 数据退役和安全擦除 ➤ 备份安全 ➤ 云服务商职责分离SOD ➤ 云服务商流程和审计	➤ 安全计算(同态加密、多方计算、差分隐私) ➤ 安全计算环境(TPM、TEE) ➤ 加密算法 ➤ 隐私保护算法 ➤ 计算环境隔离	➤ 传输加密 ➤ 身份验证 ➤ 传输抗抵赖性 ➤ 边界安全 ➤ 数据外包安全

核心问题挑战

- 降低密码接入门槛
- 传统密码技术上云支持
- 降低密码接入成本

难做

密码产业人才短缺，开发门槛高，密码行业尚处于产业规模化发展的初期阶段

难用

密码算法、密码产品、密码应用三者明显脱节，用户需要大量的开发工作

难管

密码应用分散，行业缺乏统一化标准，密码技术应用及运维管理工作复杂

云数据全生命周期保护

- 数据分级与治理，确保云上敏感数据从生成、存储、流动、使用到销毁等数据全生命周期的加密策略的应用

云产品加密密钥管理

- 云产品，如云硬盘、云存储、云数据库等精细化数据加密管控，密钥策略集中管控、安全分发、多租户隔离等挑战；

密码方案云环境适配

- 传统密钥管理系统方案与云平台架构难以融合，合规化硬件密码机部署困难，多租户管理、权限管控困难，接口不适配等

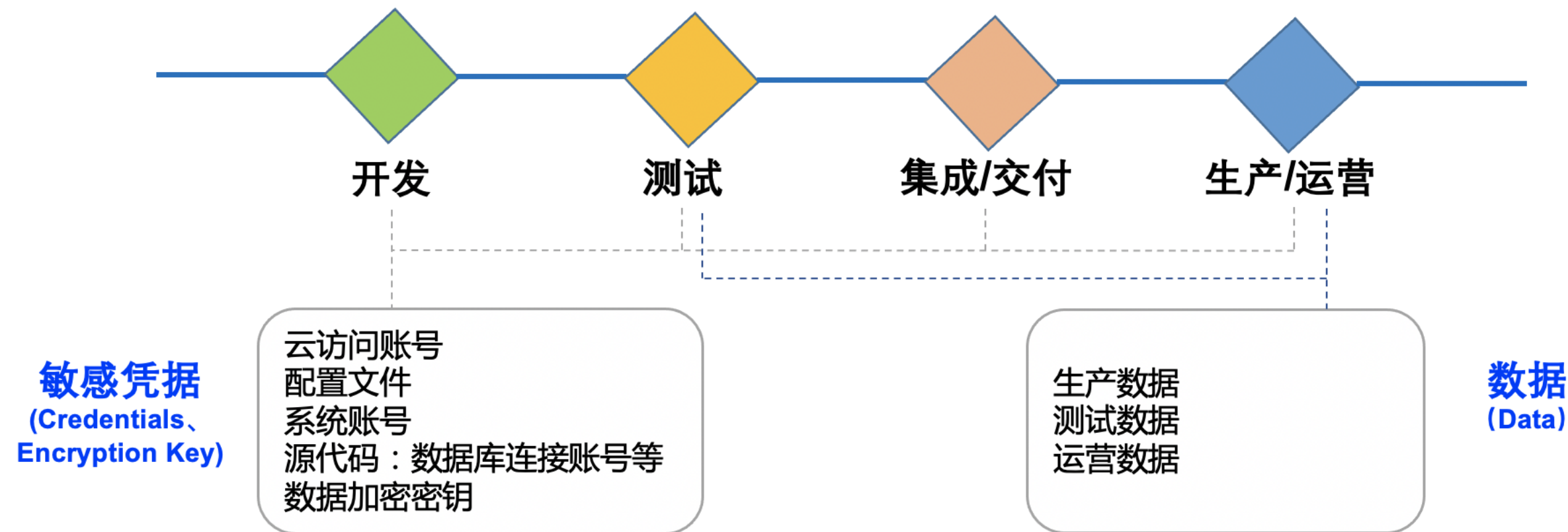
密钥权限租户主管控

- 云数据加密与密钥管理分离，密钥全生命周期由租户自主管控，包括密钥访问身份与策略管控、密钥材料、加密算法等



核心问题挑战

- 各环境下凭据的统一管控
- 解决明文配置和硬编码问题
- 资源权限控制
- 操作和资源获取监控审计
- 敏感数据加密存储
- 敏感数据脱敏



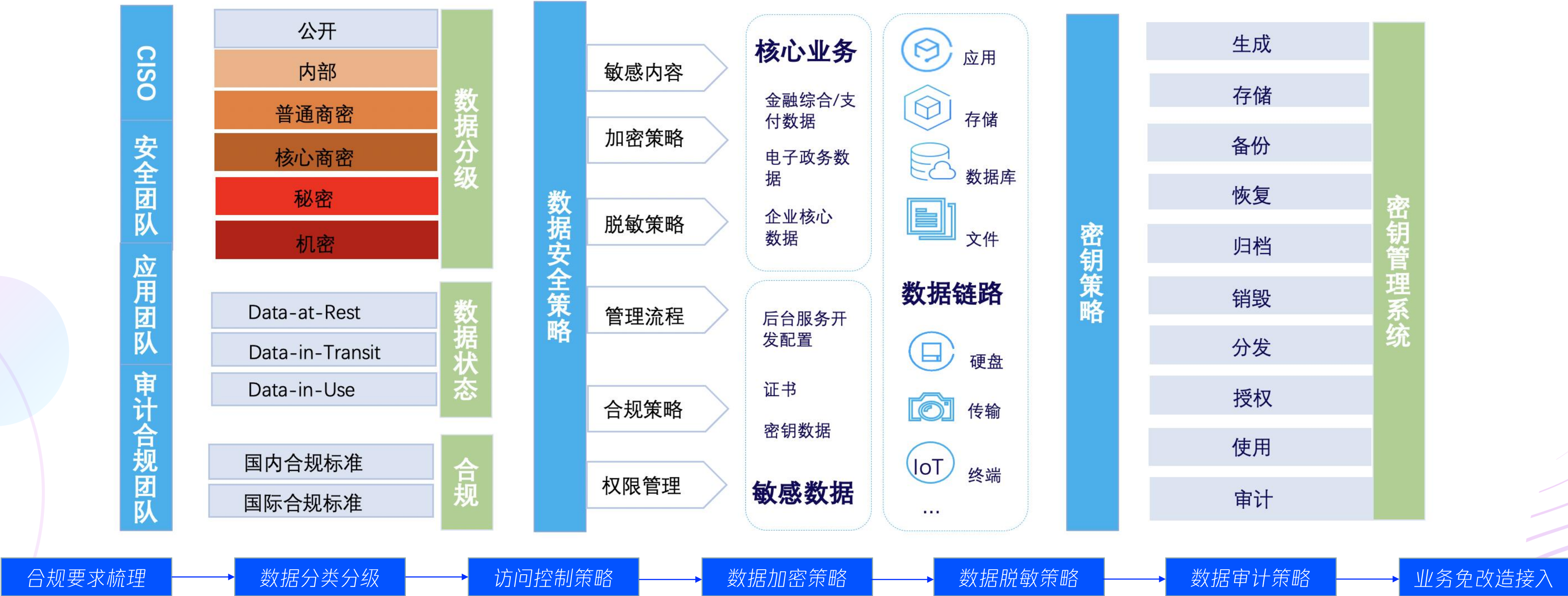
系统各阶段面临的风险：

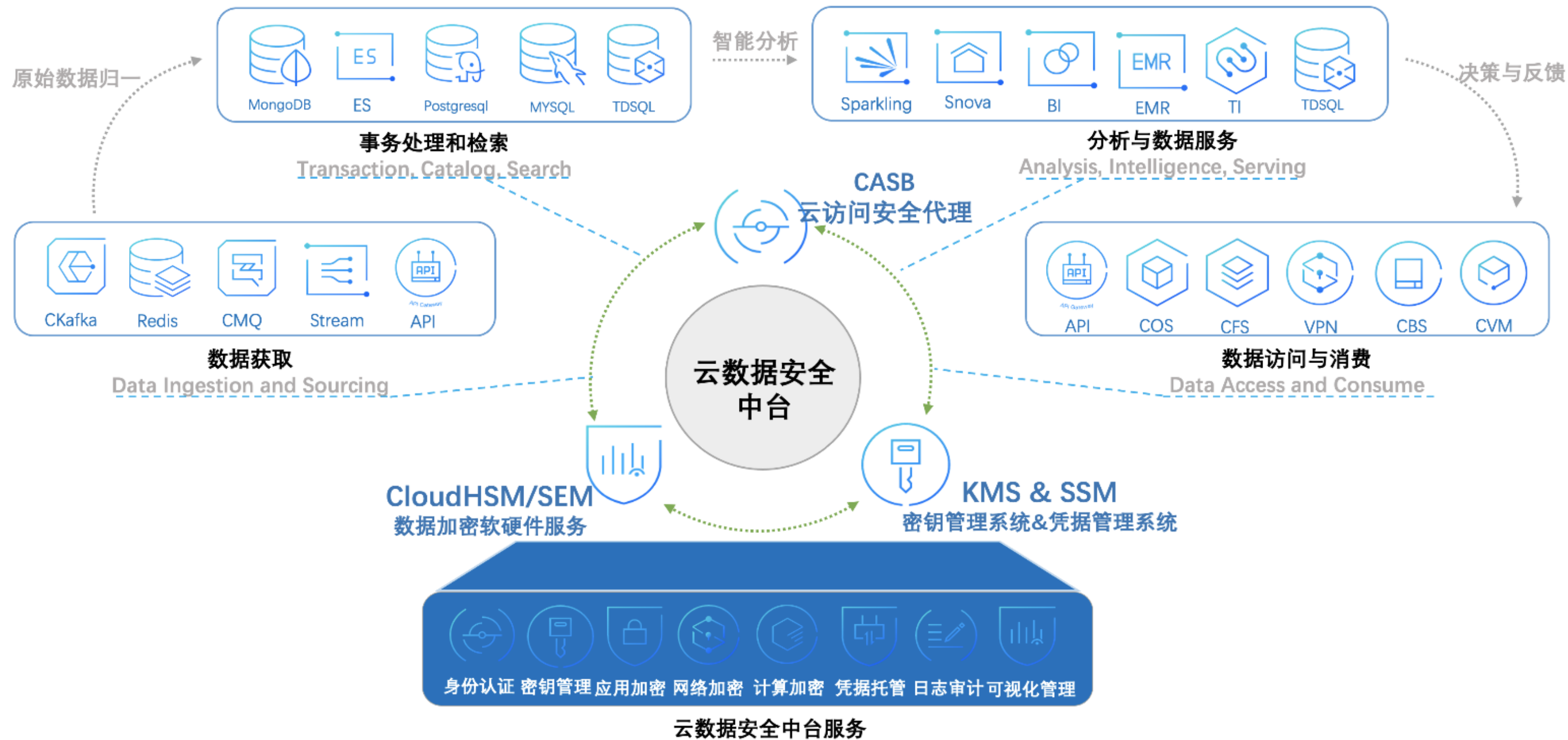
开发：意识疏忽泄露源代码中包含的敏感凭据和密钥

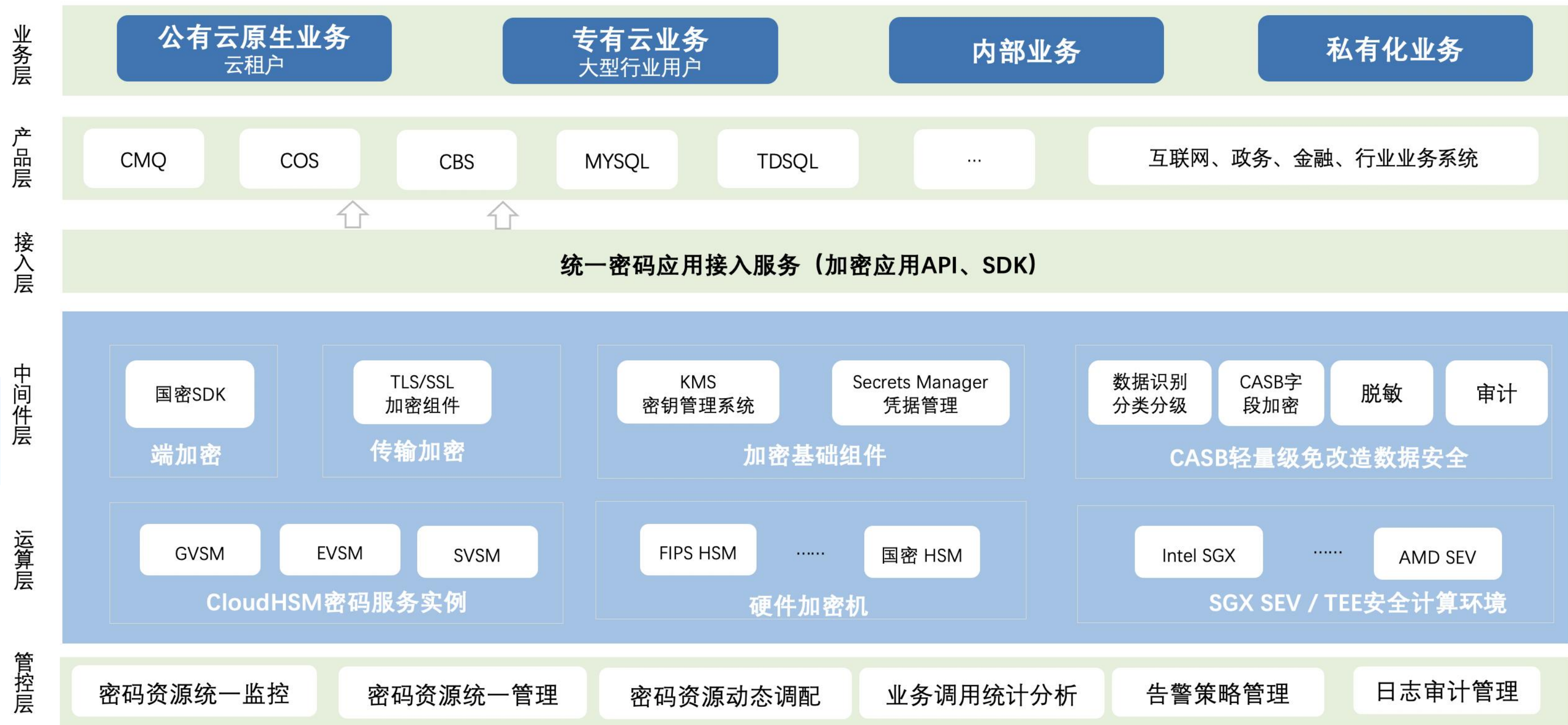
测试：暴露高风险的测试数据库访问端口和弱账号等、敏感数据明文存储

部署/交付：临时环境中的数据访问端口，薄弱配置导致的安全问题

生产/运营：账号口令泄露、破解、弱口令，缺乏保护的隐私数据和密钥







3 腾讯云数据安全和隐私保护解决方案介绍

1 密码应用全面性

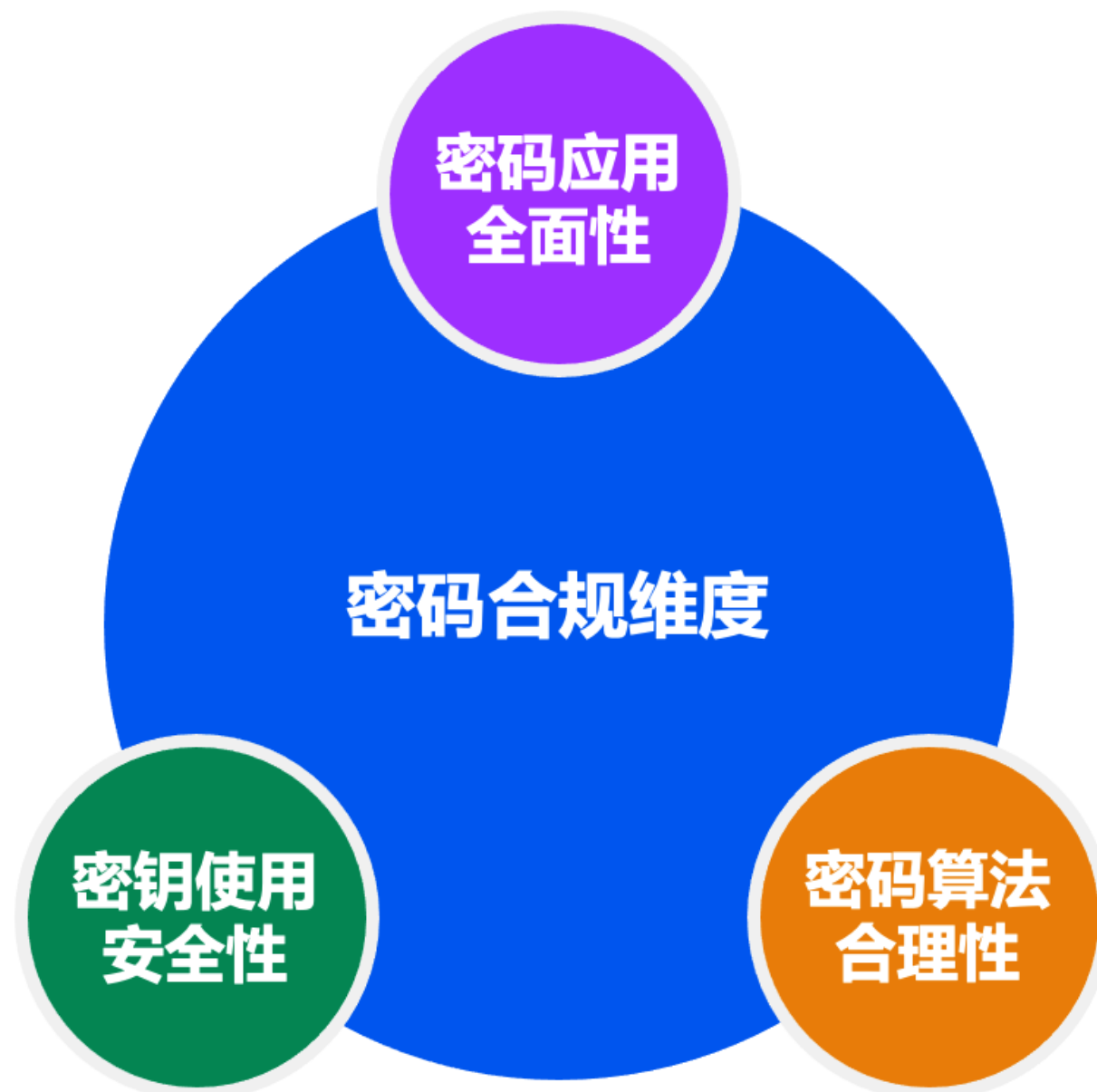
关键数据加密存储、重要角色强身份认证登录、HTTPS加密通道、数据交换加密、系统配置信息加密（帐号口令）等应加密场景

2 密钥使用安全性

密钥管理、密码运算所采用的产品或设备是否具有国密型号证书，包括密钥管理系统、加解密运算设备、数字证书设备、加密卡等

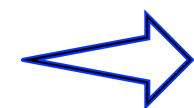
3 密码算法全理性

所采用的密码算法或技术是否经过论证，是否符合国密局、行业监管的要求，算法应用是否得当



核心关注点

- 数据上云，密钥如何管理？
- 如何满足合规的要求？
- 云上的密钥是否安全可信？
- 我的密钥会被盗取滥用吗？



腾讯云KMS服务架构

硬件级安全合规

密钥生命周期管理

细粒度权限控制

监控审计

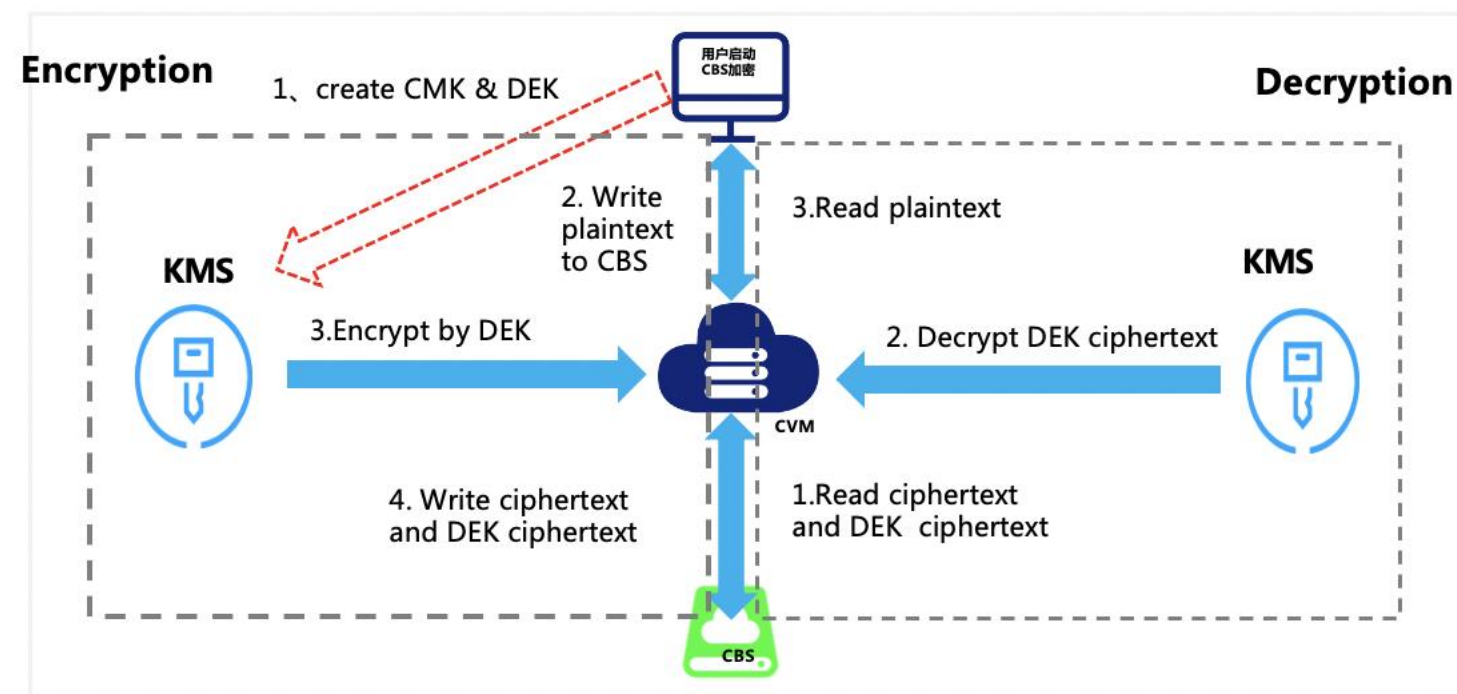
BYOK

云原生

主要解决问题

- 数据上云存储加密
- 业务0工作量
- 安全合规的密钥管控

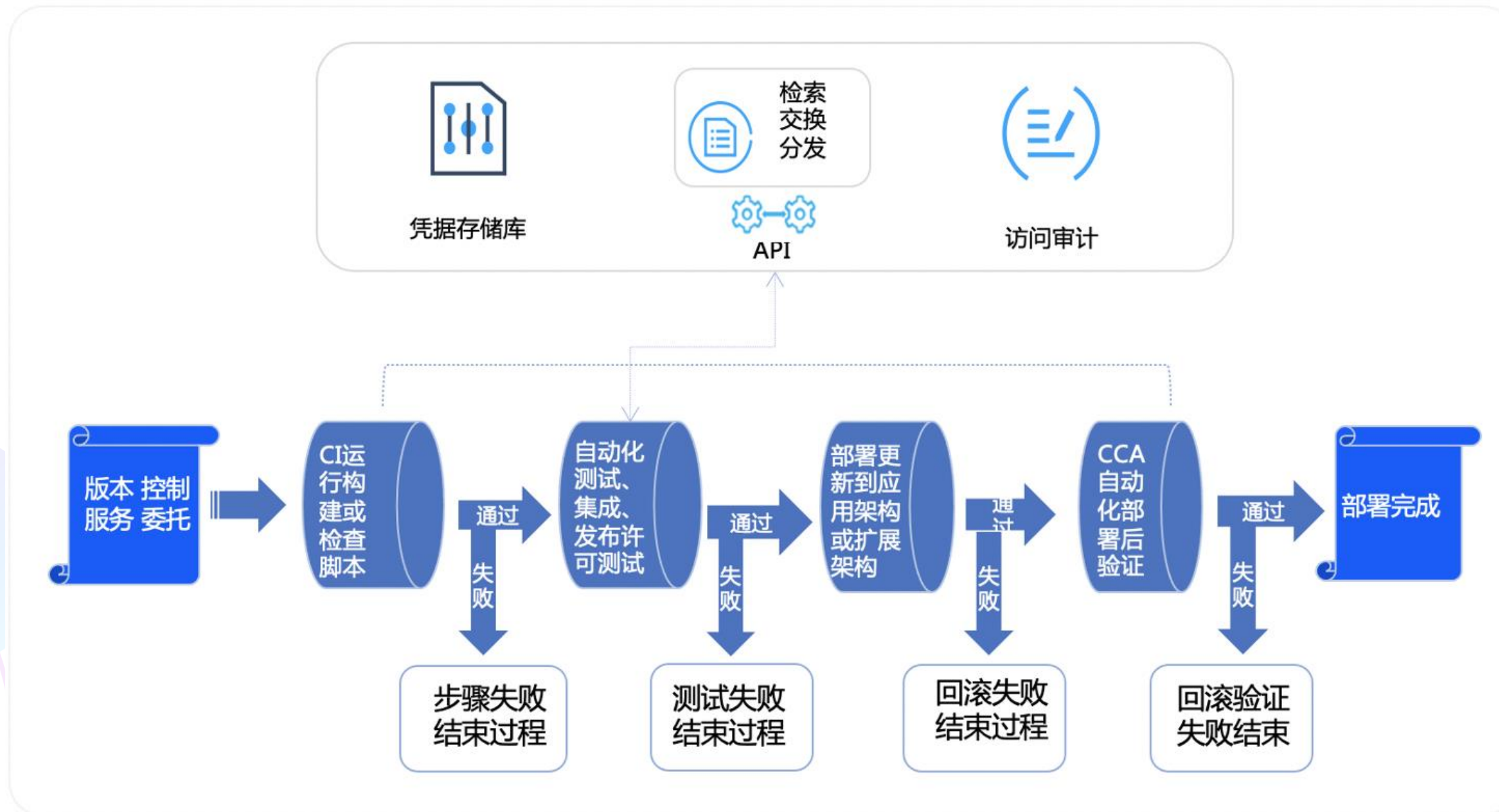
- 云产品集成KMS提供透明数据加密
- 密钥所有权归属用户，提供完全自主管控能力
- 用户对加密流程无感知，一键加密



The flow of CBS TDE

KMS





Managing Secrets and Privileged Access in an Agile, DevOps Environment, 2018, gartner

敏感凭据硬编码

- 为保障DevOps的持续集成/交付 (CI/CD)、自动化, 大量敏感凭据采用明文形式, 硬编码写入程序、配置文件、环境变量、编译脚本中

特权账户泛滥风险

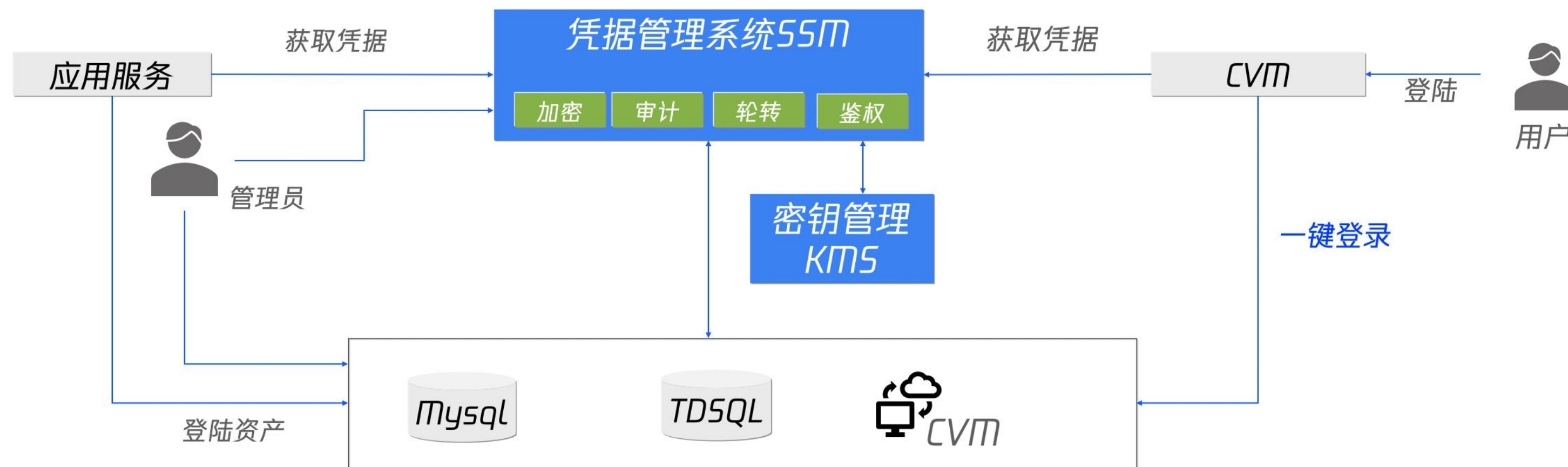
- 为保障DevOps的快速性, 敏捷性, 普遍存在特权账户泛滥现象。一旦账户泄露, 将造成严重的数据安全风险。

凭据安全管理挑战

- DevOps环境下, 大量敏感账户信息、Tokens、证书、SSH密钥、API密钥管理繁杂。需要在保障DevOps特性的同时, 保障安全性。

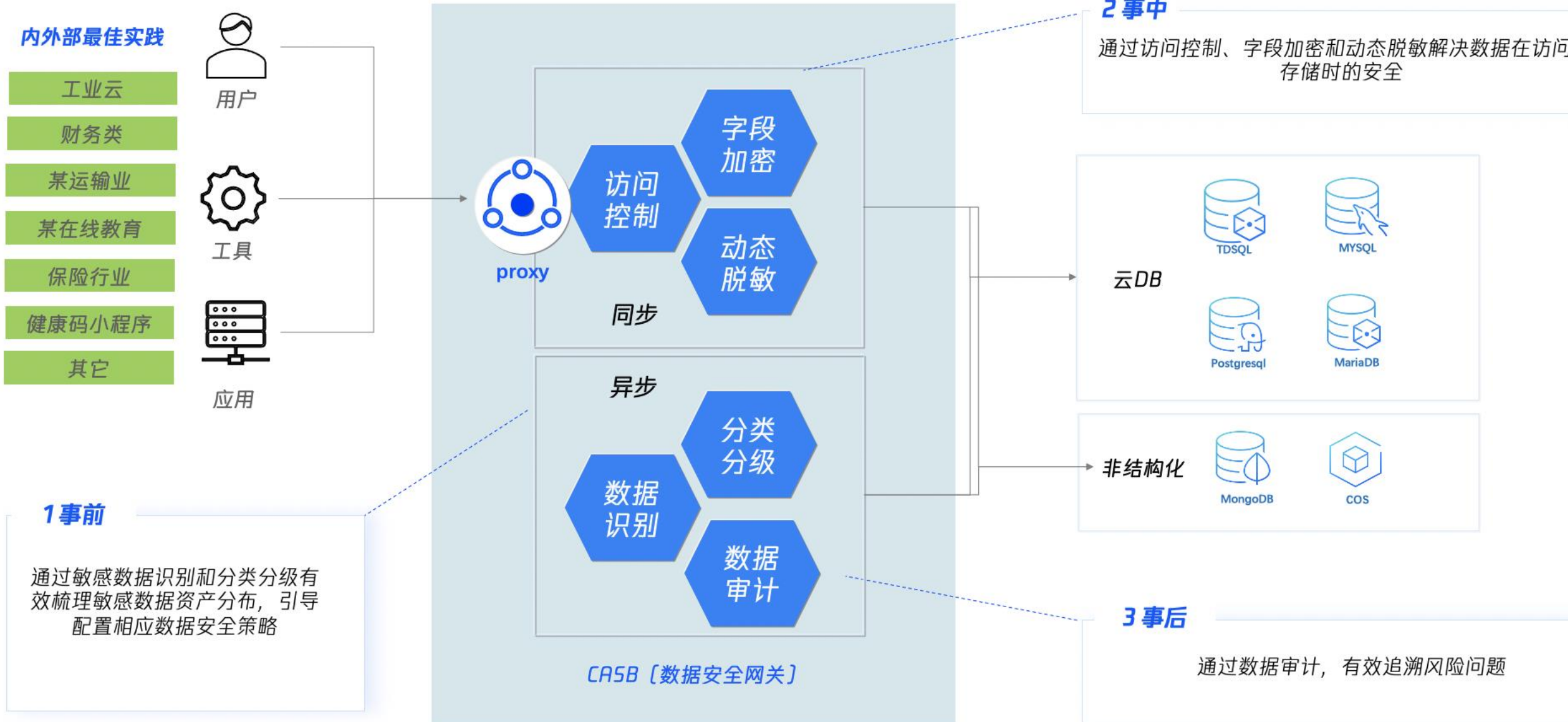
解决痛点

- 用户云上各类敏感账号密码类凭据管理分散，经常出现账号泄漏导致的数据安全问题，通过SSM统一凭据托管，解决用户凭据易泄漏问题。
- SSM 和各类云产品集成的方案，提供了**KMS加密、使用审计、凭据的自动定期轮转、身份鉴权、CVM一键安全登陆**等安全易用特性，有效解决了敏感信息明文编码，账号密码易泄漏，CVM 一键登陆，人员离职密码更新等场景的问题。

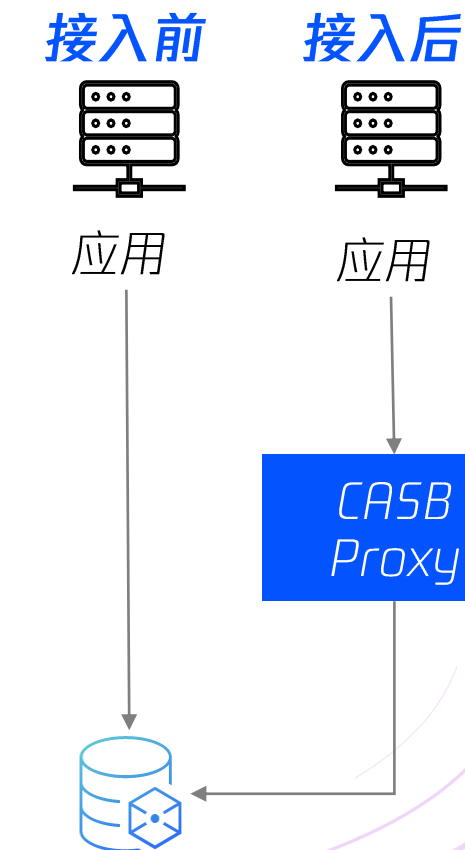


主要痛点

- 数据敏感资产梳理困难
- 加密和脱敏业务改造量大
- 密码技术方案实施成本高
- 各数据安全产品分散，运维部署、管理成本高
- 密评和合规要求难以应对



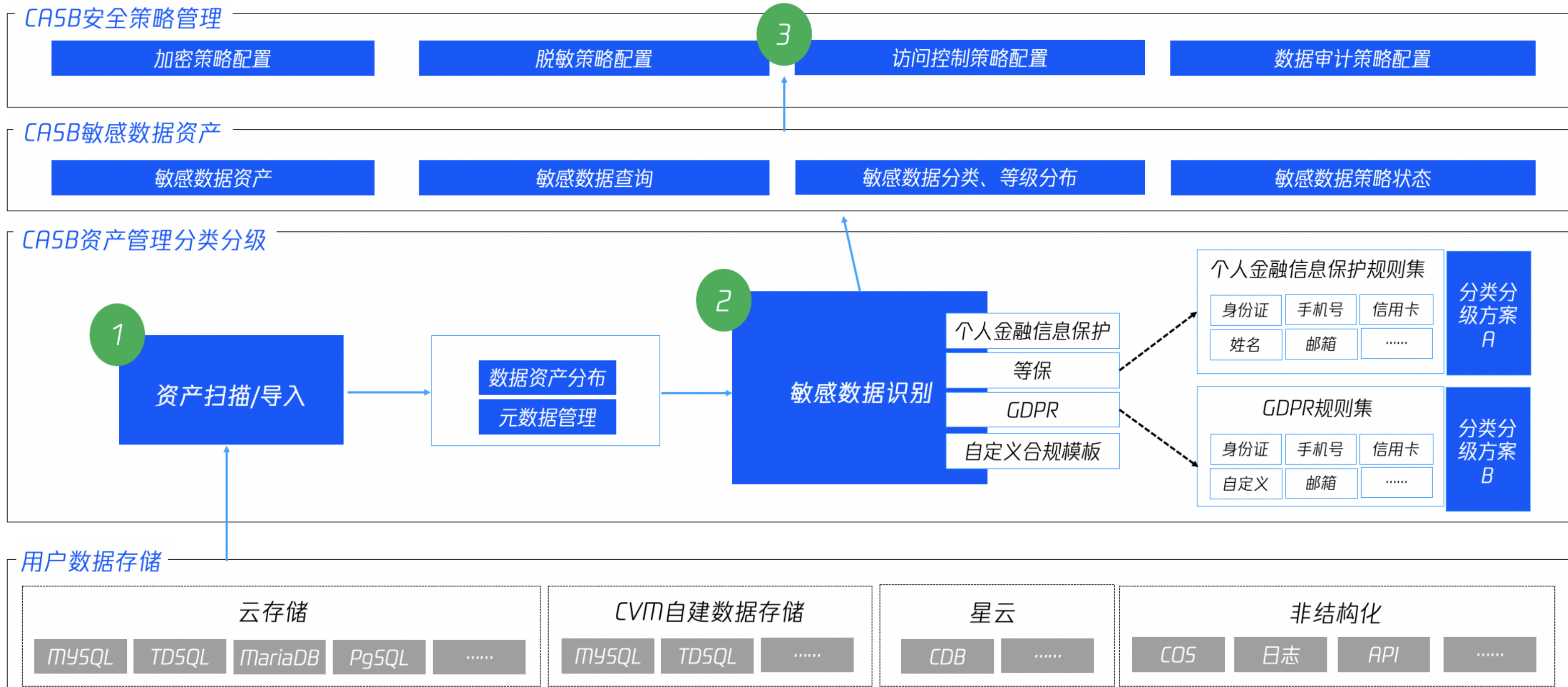
极简的接入方式

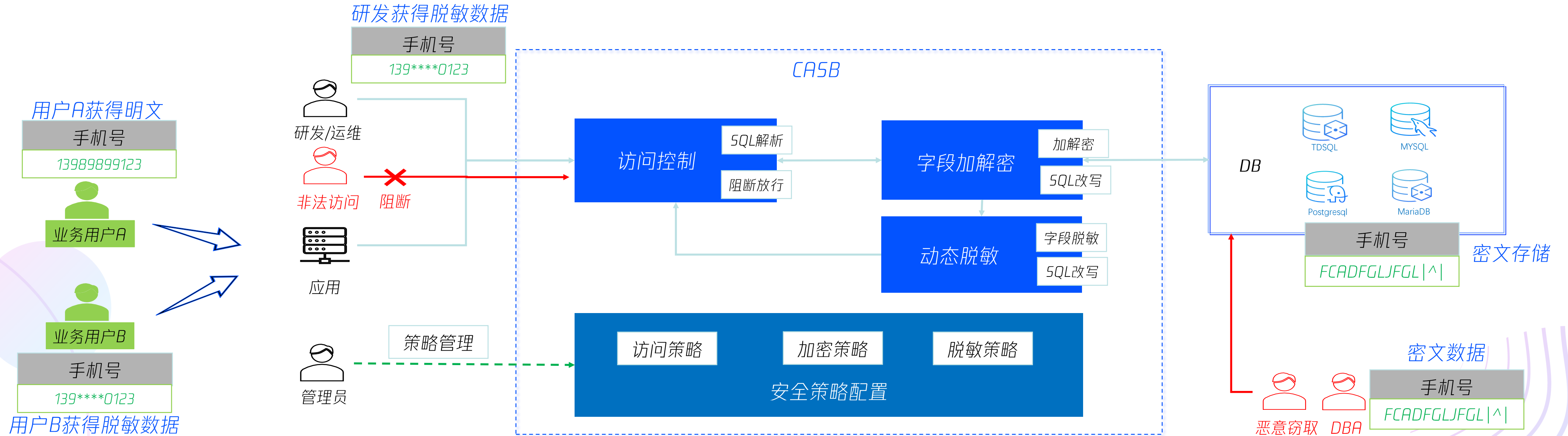


云访问安全代理CASB一站式解决数据安全问题，提供业务免改造的接入方式

主要痛点

- 分类分级各行业要求不同
- 不同企业有自定义数据管理规范
- 人工分析效率低
- 非结构化数据量大





国密
最佳实践

国密算法选择

国密密钥管理

凭据安全托管

终端安全

国密传输安全

数据加密存储

国密终端

国密安全控件

小程序安全控件

移动端安全控件

移动终端

国密协同签名

抗白盒攻击

白盒密钥

国密传输

国密SSL [SM2+SM3]

国密PaaS
中间件

密钥管理KMS

密钥管理

对称加密

非对称加密

签名验签

密钥轮转

加密机接入

权限管理

监控审计

云产品集成

凭据管理SSM

KMS加密

凭据轮转

MySQL集成

权限管理

监控审计

CVM 集成

版本管理

版本管理

TDSQL集成

存储加密CASB

字段加密

透明代理

KMS密钥管理

访问控制

国密
算法基础

国密算法SDK

SM2

SM3

SM4

多语言

跨平台

高性能

信封加密Encryption SDK

信封加密

密钥缓存

跨地域容灾

KMS接入

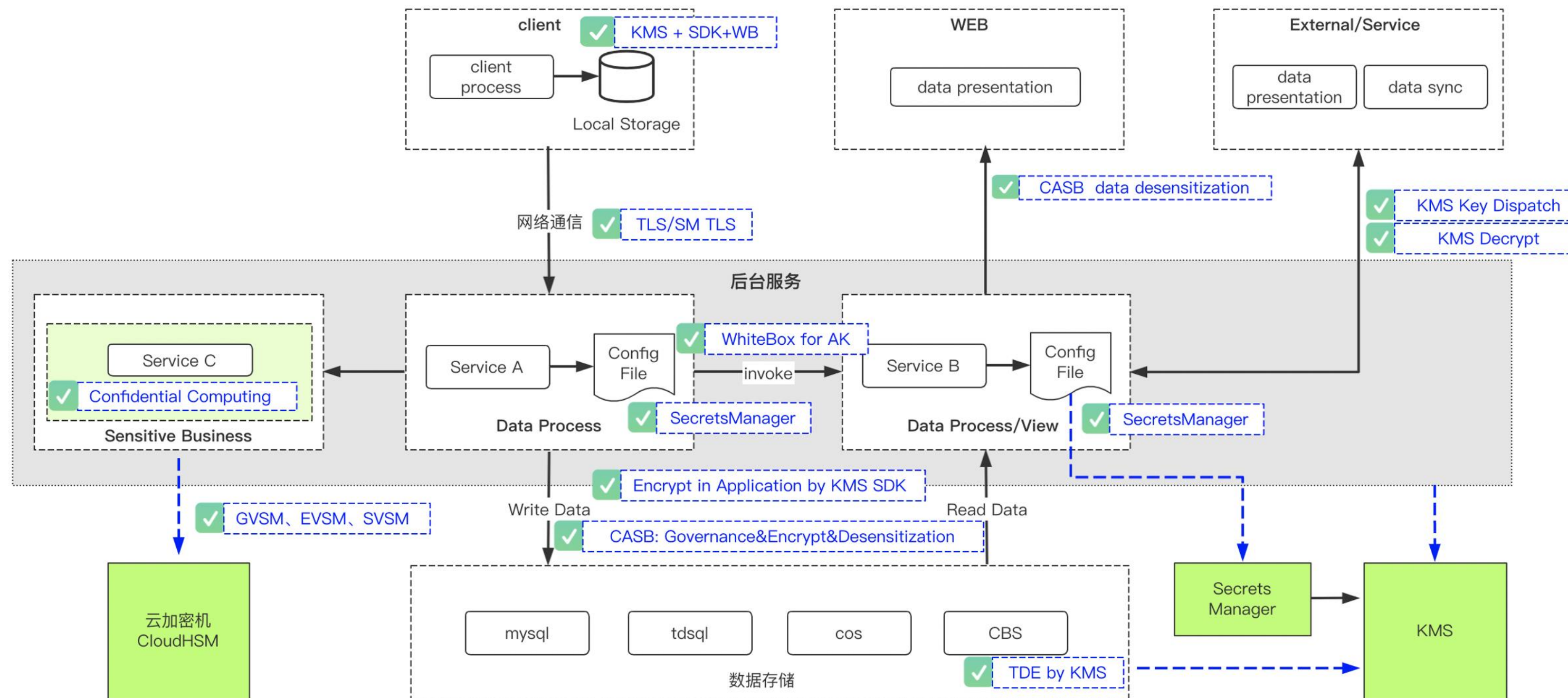
国密云密码机

国密算法

密钥管理

虚拟化实例

VPC网络隔离





感谢聆听
Thanks

● 2021首届-西部云安全峰会
Western China Cloud Security Summit 2021